Information Security

Mock 2

Academic Year 2026–2027

Duration: 1 h 30

Instructions. Answer all questions. Responses must be *concise* and every claim must be *justified*. Calculators and external material are not permitted.

Part I – Web Privacy and Data Protection

An online marketplace operates at the host `shop.example`. Its relevant features are:

- Each seller may customise a storefront page with their own HTML and JavaScript, served from `http://shop.example/store/<seller>/`. For example, a seller named Alice controls `http://shop.example/store/alice/`. The same content is also reachable over HTTPS.
- Buyers manage their account and checkout at `http://shop.example/account/`. A buyer signs in with an email address and password; on success the server issues a session cookie.
- The server accepts connections over both HTTP and HTTPS.

The session cookie has the following attributes:

Attribute	Value
Name	`session`
Value	(random session identifier)
Path	`/`
Domain	`shop.example`
SameSite	`Strict`
Secure	set

The cookie does *not* carry the `HttpOnly` attribute.

Q1. Bob signs in to his account over HTTPS and then follows a link that is served over plain HTTP. Throughout, the attacker Eve passively monitors his network traffic. Can Eve recover the value of Bob's `session` cookie? State your reasoning.

Q2. Alice may publish arbitrary HTML and JavaScript at `http://shop.example/store/alice/` (also reachable over HTTPS), but holds no other access: she cannot alter the marketplace software and cannot read its logs. Determine whether Alice can obtain the `session` cookie of a buyer who, while signed in, visits her storefront. If she can, describe concretely how she would construct her page to capture it; if she cannot, explain what prevents her.

Q3. The marketplace operators weigh several changes to the way the cookie is issued.

(a) Suppose the `HttpOnly` attribute is added to the cookie. State, with reasons, how this affects your answers to Questions 1 and 2.

(b) Suppose instead that the `Secure` attribute is removed (and `HttpOnly` remains unset). State, with reasons, how this affects your answers to Questions 1 and 2.

Q4. For the two independent scenarios below, return to Alice's situation in Question 2 and disregard the attribute changes considered in Question 3.

(a) The account and checkout service is moved to the host `checkout.shop.example` and the cookie's `Domain` attribute is set to `checkout.shop.example`, while storefronts remain at `shop.example/store/...`. Does your answer to Question 2 still hold? Explain.

(b) Alternatively, the cookie keeps `Domain=shop.example`, but storefronts are moved to per-seller subdomains, so that Alice's storefront is now at `alice.shop.example`. Does your answer to Question 2 still hold? Explain.

Part II – Cryptography

Scenario. Alice is assembling cryptographic building blocks for a project. The adversary Eve can observe all network traffic, store the messages she sees, and on occasion inject or replace messages of her own.

A. Ciphers and public-key trust

Q1. Consider the affine cipher over the 26-letter alphabet, with letters numbered $\mathrm{A} = 0, \mathrm{B} = 1, \ldots, \mathrm{Z} = 25$. Encryption maps a letter m to $E(m) = (a\,m + b) \bmod 26$. Alice chooses the multiplier $a = 5$ and the shift $b = 8$.

(a) Encrypt the plaintext `HELP`. Show the computation for each letter.

(b) State the decryption function, computing the required value of $a^{-1} \bmod 26$ and showing how you obtain it.

Q2. Alice holds what she believes to be Bob's public key, but Eve may have substituted a key of her own. Explain how a certificate authority enables Alice to gain confidence that a given public key genuinely belongs to Bob. Describe the steps involved.

B. Analysis of a sealed-prediction protocol

Two colleagues, Alice and Bob, each wish to predict the result of an upcoming match and later settle, over an insecure network with no trusted third party, who predicted correctly. The design goals are that neither party can change its prediction once the match result is known, and that neither can learn the other's prediction before committing to its own.

Q3. Consider the naive protocol in which each party simply announces its prediction, in the clear, before the match. Identify the opportunities for cheating that this protocol permits.

Q4. To address this, Alice proposes the following scheme:

- Each party encrypts its own prediction under a secret key it selects (Alice uses K_A, Bob uses K_B) and sends the resulting ciphertext before the match.
- After the match, each party reveals its key, and the other decrypts and learns the prediction.

(a) Identify any remaining opportunities for cheating, and justify your answer.

(b) Could the symmetric cipher be replaced by a public-key encryption scheme? Would such a substitution make the protocol secure? Justify your answer.

Q5. Alice and Bob now consider using a cryptographic hash function H.

(a) Design a protocol, based on H, that meets the two design goals stated above. Specify the messages exchanged and the verification each party performs.

(b) Define the *collision-resistance* property of a cryptographic hash function. What happens to your protocol if H fails to be collision-resistant? Explain.

(c) Define the *preimage-resistance* property of a cryptographic hash function. What happens to your protocol if H fails to be preimage-resistant? Explain.

— End of questions —